

Third-Party & Vendor Risk Assessment

Vendor Intake, Criticality Tiering, Security Questionnaire Review, and Decision Memo

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Vendor Risk Manager, Information Security

Version 1.0 | Classification: Confidential – Internal Use

1. Purpose

This document establishes SecurityGroup101's process for assessing the information security and privacy risk of third-party vendors prior to onboarding, and applies that process to three vendors under active review in support of the company's cloud-based payment processing platform. The program satisfies Annex A.5.19 through A.5.22 of ISO/IEC 27001:2022, addresses GLBA Safeguards Rule oversight of service providers, and aligns to PCI DSS v4.0 Requirement 12.8 for third-party service providers with access to the cardholder data environment (CDE).

2. Scope

This assessment covers three vendors proposed for onboarding: a cloud infrastructure-as-a-service (IaaS) provider, a payment gateway / processing subprocessor, and a payroll and HR information system provider. Each vendor was evaluated using a standard intake questionnaire, scored against a criticality tiering model, and reviewed against its submitted security documentation (SOC 2 report, security questionnaire response, and policy excerpts).

3. Vendor Intake Questionnaire

The intake questionnaire is completed by the business owner and security reviewer at the start of every new vendor engagement. Responses below are shown for CloudHost IaaS, the highest-criticality vendor under review.

Field	Response
Vendor name	CloudHost IaaS, Inc.
Business owner / requestor	Cloud Infrastructure Lead
Service description	Infrastructure-as-a-Service hosting for production payment-processing workloads, including compute, storage, and network services.
Does the vendor access, process, or store cardholder data?	Yes – hosts the cardholder data environment (CDE).
Does the vendor access, process, or store other customer PII?	Yes – customer account and transaction metadata.
Does the vendor subcontract any part of the service (fourth parties)?	Yes – regional data center operators under the provider's published subprocessor list.
Where is data stored / processed (geography)?	United States (primary region), with encrypted backup replication to a secondary U.S. region.
Does the vendor have independent attestation (SOC 2, ISO 27001)?	Yes – SOC 2 Type II (Security, Availability, Confidentiality) and ISO/IEC 27001:2022 certified.
Encryption in transit and at rest?	Yes – TLS 1.2+ in transit, AES-256 at rest.
Termination / offboarding data return or deletion terms?	Yes – 90-day data retrieval window followed by certified deletion, per contract Exhibit C.

4. Vendor Criticality Tiering Model

Each vendor is scored 1 (lowest) to 5 (highest) across four weighted factors. A composite score of 16–20 is tiered Critical, 11–15 High, 6–10 Medium, and 4–5 Low. Tier determines the depth of security review, contract security requirements, and reassessment frequency.

Scoring Factor	Definition
Data sensitivity	Type and volume of data accessible (PII, PHI, cardholder data, financial records).
Production / system access	Whether the vendor has connectivity to production systems or the CDE.
Privileged access	Whether vendor personnel hold administrative or elevated credentials.
Regulatory / compliance impact	Exposure created under PCI DSS, GLBA, FFIEC, or SOX if the vendor is compromised.

Vendor	Data Sensitivity	Production Access	Privileged Access	Regulatory Impact	Composite Score	Tier
CloudHost IaaS	5	5	4	5	19	Critical
PayProc Gateway	5	4	3	5	17	Critical
HR Vendor (Payroll/HRIS)	3	2	2	3	10	Medium

CloudHost IaaS and PayProc Gateway are tiered Critical and require annual onsite or virtual control validation, mandatory security addenda in contract, and quarterly monitoring of their independent attestation status. The HR Vendor is tiered Medium and requires standard contract security clauses with biennial reassessment.

5. Security Questionnaire Review

Security questionnaire responses and supporting attestation documents were reviewed against SecurityGroup101's minimum control baseline for Critical-tier vendors. The review for PayProc Gateway identified one finding, documented below in condition / criteria / cause / effect / recommendation format, consistent with the organization's internal audit finding standard.

Finding TPR-001 — Privileged Account Access Review Not Performed Annually

Element	Detail
Vendor	PayProc Gateway (payment processing subprocessor)
Condition	PayProc Gateway's security questionnaire response indicates privileged account access reviews are performed ad hoc rather than on a defined schedule, and the most recent documented review was completed 14 months prior to submission.
Criteria	ISO/IEC 27001:2022 Annex A.5.18 (Access rights) and PCI DSS v4.0 Requirement 7.2.4 both require periodic review of user accounts and access privileges, at minimum annually for service providers with access to the CDE.
Cause	PayProc Gateway has not yet formalized a recurring access review cadence into its internal governance calendar.
Effect	Stale or excessive privileged access at the vendor increases the likelihood that a compromised or former vendor employee credential could be used to access SecurityGroup101 transaction data without detection.
Recommendation	Require PayProc Gateway to formalize and evidence an annual privileged access review as a condition of contract renewal, with first evidence of a completed review due within 90 days of contract execution. Track to closure in the Vendor Risk Remediation Log.

No findings were identified for CloudHost IaaS or the HR Vendor at the time of this review; both provided current SOC 2 Type II reports without qualified opinions on the relevant trust service criteria.

6. Risk Register Excerpt

Risk ID	Risk Description	Likelihood (1-5)	Impact (1-5)	Treatment	Residual Risk
VR-01	Vendor privileged access not reviewed annually (PayProc Gateway)	4	4	Reduce via contractual remediation (TPR-001)	Medium
VR-02	Fourth-party subcontracting by CloudHost IaaS without disclosed change notice	3	4	Reduce via contract clause requiring 30-day subprocessor change notice	Medium
VR-03	Concentration risk from single-region primary hosting	2	5	Accept – mitigated by documented multi-region DR failover	Low

7. Executive Decision Memo

To: Vendor Risk Steering Committee

From: Maxine Jones, GRC Analyst

Re: Onboarding Recommendation — CloudHost IaaS, PayProc Gateway, HR Vendor

Based on the intake review, criticality tiering, and security questionnaire assessment documented in this package, the following onboarding decisions are recommended:

Vendor	Decision	Rationale / Conditions
CloudHost IaaS	Approve	No conditions beyond standard Critical-tier contract security addendum and annual SOC 2 report review.
PayProc Gateway	Approve with conditions	Approve onboarding contingent on remediation of Finding TPR-001 (annual privileged access review) within 90 days of contract execution, and inclusion of a 30-day subprocessor change-notice clause.
HR Vendor	Approve	No conditions; standard Medium-tier contract clauses apply, with reassessment in 24 months.

This recommendation will be re-evaluated if any vendor experiences a reportable security incident, a material change in subcontracting arrangements, or a lapse in independent attestation. Annual reassessment is scheduled for all Critical-tier vendors; biennial reassessment applies to the Medium-tier vendor.